

CCSHAU Website — API Documentation

Project: CCSHAU Official University Website

API layer: Next.js App Router Route Handlers (`apps/web/src/app/api`)

Base URL (local): `http://localhost:3000`

Base URL (production): value of `NEXT_PUBLIC_SITE_URL`

Auth session: Supabase Auth cookies (HTTP-only), set by login / cleared by logout

Content type: `application/json` unless noted

1. Overview

Category	Endpoints	Auth
Health	<code>GET /api/health</code>	Public (detailed = secret)
Auth	Login, logout, change password, password reset	Mixed
Downloads	<code>GET /api/downloads/{id}/file</code>	Public (published files)
Cron	Process tenders / downloads	Bearer <code>CRON_SECRET</code>

Notes

- Most CMS CRUD uses **Server Actions**, not REST routes. This document covers **HTTP Route Handlers only**.
 - Validation uses **Zod** schemas in `apps/web/src/lib/validations/auth.ts`.
 - CAPTCHA and account lockout apply when enabled in site settings / env.
 - Successful auth responses set or clear **Supabase session cookies** (browser clients must send credentials / cookies).
-

2. Common conventions

2.1 Request headers

Header	When
<code>Content-Type: application/json</code>	All POST JSON bodies
<code>Authorization: Bearer <CRON_SECRET></code>	Cron routes; optional detailed health
<code>Cookie (session)</code>	Authenticated routes after login

2.2 Success / error shape (auth)

Typical JSON:

```
{ "success": true }
```

```
{ "success": false, "error": "Human-readable message" }
```

Validation may include:

```
{
  "success": false,
  "error": "Validation failed",
  "fieldErrors": { "email": ["Enter a valid email address"] }
}
```

2.3 HTTP status codes

Code	Meaning
200	Success
3xx	Redirect (download file)
400	Bad request / validation / CAPTCHA
401	Unauthorized / invalid credentials / missing session
423	Locked (account or IP lockout)
429	Rate limited
500	Server error
503	Service unavailable (config / DB / lockout store)
404	Resource not found

2.4 Rate limits

Key	Limit	Window
Login per IP	30	15 minutes
Password reset per IP	5	15 minutes
Password reset per email	3	15 minutes

2.5 Client IP

Taken from `x-forwarded-for` (first hop) or `x-real-ip` (used for rate limit, lockout, audit).

3. Endpoint catalog

3.1 Health

`GET /api/health`

Liveness and optional detailed environment posture.

Item	Value
Auth	None for basic. Detailed: non-production or <code>HEALTH_DETAILED=true</code> or <code>Authorization: Bearer <CRON_SECRET HEALTH_CHECK_SECRET></code>

Response	JSON
----------	------

Basic response (production, unauthenticated)

```
{
  "status": "ok",
  "timestamp": "2026-08-27T05:00:00.000Z"
}
```

Detailed response (dev / authorized)

```
{
  "status": "ok",
  "phase": "0",
  "project": "CCSHAU Official University Website",
  "timestamp": "2026-08-27T05:00:00.000Z",
  "environment": {
    "siteUrl": "https://example.com",
    "supabase": "connected",
    "supabaseProjectId": "fvveqziyusjgqejewkfp",
    "schemaVersion": "...",
    "supabaseError": null,
    "missingEnvVars": [],
    "powerAutomate": "configured",
    "captcha": { "enabled": false, "credentials": "not_configured" },
    "email": { "enabled": true, "credentials": "configured" },
    "analytics": "on_hold"
  },
  "stack": {
    "frontend": "Next.js",
    "database": "Supabase PostgreSQL",
    "dbNameingPrefix": "CCSHAU_",
    "hosting": "Vercel",
    "email": "Microsoft Power Automate"
  }
}
```

cURL

```
curl -s http://localhost:3000/api/health
```

3.2 Auth — Login

POST /api/auth/login

Signs in a CMS user and sets the Supabase session cookie.

Item	Value
Auth	Public

Body	JSON (loginSchema)
Side effects	CAPTCHA check, IP rate limit, account/IP lockout, audit log, lockout email alert

Request body

Field	Type	Required	Rules
email	string	Yes	Valid email
password	string	Yes	Min 8 characters
captchaToken	string	No*	Required when CAPTCHA is enabled

*When CAPTCHA is disabled in settings, token may be omitted.

Example request

```
POST /api/auth/login HTTP/1.1
Content-Type: application/json

{
  "email": "admin@example.com",
  "password": "password1",
  "captchaToken": "optional-token"
}
```

Success — 200

```
{ "success": true }
```

Errors

Status	Condition
400	Invalid JSON, validation failed, CAPTCHA failed
401	Invalid email/password
423	Account or IP locked (typically after 5 failures)
429	IP rate limit exceeded
500	Session could not be established
503	Auth env missing / lockout store unavailable

cURL

```
curl -i -X POST http://localhost:3000/api/auth/login \
-H "Content-Type: application/json" \
```

```
-d "{\"email\":\"admin@example.com\",\"password\":\"password1\"}" \
-c cookies.txt
```

3.3 Auth — Logout

POST /api/auth/logout

Clears the Supabase session. Writes an audit log if a user was signed in.

Item	Value
Auth	Cookie optional (always succeeds)
Body	None

Success — 200

```
{ "success": true }
```

cURL

```
curl -i -X POST http://localhost:3000/api/auth/logout -b cookies.txt
```

3.4 Auth — Change password

POST /api/auth/change-password

Changes password for the currently signed-in user. Verifies current password before update.

Item	Value
Auth	Required (session cookie)
Body	JSON (changePasswordSchema)

Request body

Field	Type	Required	Rules
currentPassword	string	Yes	Min 8
newPassword	string	Yes	Min 8; must differ from current
confirmPassword	string	Yes	Must match newPassword

Success — 200

```
{ "success": true, "message": "Password updated." }
```

Errors

Status	Condition
400	Validation / wrong current password / update failed
401	Not signed in
503	Auth service / env unavailable

3.5 Auth — Password reset request

POST /api/auth/password-reset-request

Requests a recovery email. Always returns a **generic success** when processing completes (does not reveal whether the email exists). Email is sent only for known CMS profiles.

Item	Value
Auth	Public
Body	JSON (passwordResetRequestSchema)
Side effects	Rate limits, CAPTCHA, Power Automate email, audit log

Request body

Field	Type	Required	Rules
email	string	Yes	Valid email
captchaToken	string	No*	When CAPTCHA enabled

Success — 200

```
{
  "success": true,
  "message": "If an account exists for that email, a password reset link has been sent. Check your inbox."
}
```

Errors

Status	Condition
400	Invalid body / invalid email / CAPTCHA failed
429	IP or email rate limit
503	Email not configured / admin client unavailable

Redirect target for recovery link: {SITE_URL}/admin/reset-password

3.6 Auth — Password reset confirm

POST /api/auth/password-reset-confirm

Sets a new password using an active **recovery session** (from the email link). Signs the user out afterward so they must log in with the new password.

Item	Value
Auth	Recovery session cookie required
Body	JSON (<code>passwordResetConfirmSchema</code>)

Request body

Field	Type	Required	Rules
password	string	Yes	Min 8
confirmPassword	string	Yes	Must match password
captchaToken	string	No*	When CAPTCHA enabled

Success — 200

```
{
  "success": true,
  "message": "Password updated. You can sign in with your new password."
}
```

Also clears cookie `ccshau_recovery`.

Errors

Status	Condition
400	Validation / CAPTCHA / update failed
401	Missing or expired recovery session
503	Auth service unavailable

3.7 Downloads — Public file

GET /api/downloads/{id}/file

Redirects to the stored file URL for a **published, public**, non-expired download. Increments download count via RPC.

Item	Value
Auth	Public
Path param	<code>id</code> — download UUID
Success	302/307 redirect to blob/CDN URL

Errors

Status	Condition
404	Not found / not public / expired / pending path / URL missing
503	Database not configured

cURL

```
curl -i http://localhost:3000/api/downloads/00000000-0000-4000-8000-000000000001/file
```

3.8 Cron — Process expired tenders

`GET /api/cron/process-tenders`

Fallback cron when `pg_cron` is unavailable. Calls `processExpiredTenders` RPC.

Item	Value
Auth	Authorization: Bearer <CRON_SECRET> required

Success — 200

```
{ "ok": true, "result": /* RPC payload */ }
```

Errors

Status	Condition
401	Missing/invalid secret
500	RPC error
503	Database not configured

cURL

```
curl -s http://localhost:3000/api/cron/process-tenders \
-H "Authorization: Bearer $CRON_SECRET"
```

3.9 Cron — Archive expired downloads

`GET /api/cron/process-downloads`

Archives expired downloads via `archiveExpiredDownloads` RPC.

Item	Value
Auth	Authorization: Bearer <CRON_SECRET> required

Success — 200


```
{ "ok": true, "archived": /* RPC payload */ }
```

Errors: same as process-tenders (401 / 500 / 503).

4. Environment variables (API-related)

Variable	Used by
NEXT_PUBLIC_SUPABASE_URL	Auth, health
NEXT_PUBLIC_SUPABASE_ANON_KEY	Auth
SUPABASE_SERVICE_ROLE_KEY	Admin client (downloads, reset, cron, health detail)
NEXT_PUBLIC_SITE_URL	Reset redirect, health
CRON_SECRET	Cron + optional detailed health
HEALTH_CHECK_SECRET	Optional detailed health (fallback)
HEALTH_DETAILED	Force detailed health when true
POWER_AUTOMATE_EMAIL_URL	Password reset / lockout emails
CAPTCHA keys	When CAPTCHA enabled in settings

See also: apps/web/.env.example .

5. Security summary

Control	Where
Zod validation	All auth POST bodies
CAPTCHA	Login, password reset (when enabled)
Rate limiting	Login IP, password-reset IP/email
Account / IP lockout	Login (typically 5 failures → 423 + alert email)
Audit logging	Login, logout, password change/reset
Cron Bearer secret	Both cron routes
Generic reset response	Prevents email enumeration
Session cookies	HttpOnly via Supabase SSR helpers

6. Source map

Endpoint	Implementation
GET /api/health	apps/web/src/app/api/health/route.ts

POST /api/auth/login	apps/web/src/app/api/auth/login/route.ts
POST /api/auth/logout	apps/web/src/app/api/auth/logout/route.ts
POST /api/auth/change-password	apps/web/src/app/api/auth/change-password/route.ts
POST /api/auth/password-reset-request	apps/web/src/app/api/auth/password-reset-request/route.ts
POST /api/auth/password-reset-confirm	apps/web/src/app/api/auth/password-reset-confirm/route.ts
GET /api/downloads/[id]/file	apps/web/src/app/api/downloads/[id]/file/route.ts
GET /api/cron/process-tenders	apps/web/src/app/api/cron/process-tenders/route.ts
GET /api/cron/process-downloads	apps/web/src/app/api/cron/process-downloads/route.ts
Zod schemas	apps/web/src/lib/validations/auth.ts
Handler tests	apps/web/src/app/api/api-routes.test.ts
HTTP smoke tests	apps/web/src/smoke/api-routes.smoke.test.ts

7. Testing the APIs

```
# From repo root
npm test --workspace=web -- src/app/api/api-routes.test.ts

# Live smoke (dev server must be running)
npm run test:smoke --workspace=web
```

8. Out of scope (this API surface)

- Admin CMS CRUD (pages, news, tenders, users, etc.) — implemented as **Server Actions**, not REST
- Public page data — SSR / Server Components + Supabase queries
- Direct browser → Supabase PostgREST for admin writes — **not used**

CCSHAU Website — API Documentation

Generated from Route Handlers in `apps/web/src/app/api`